

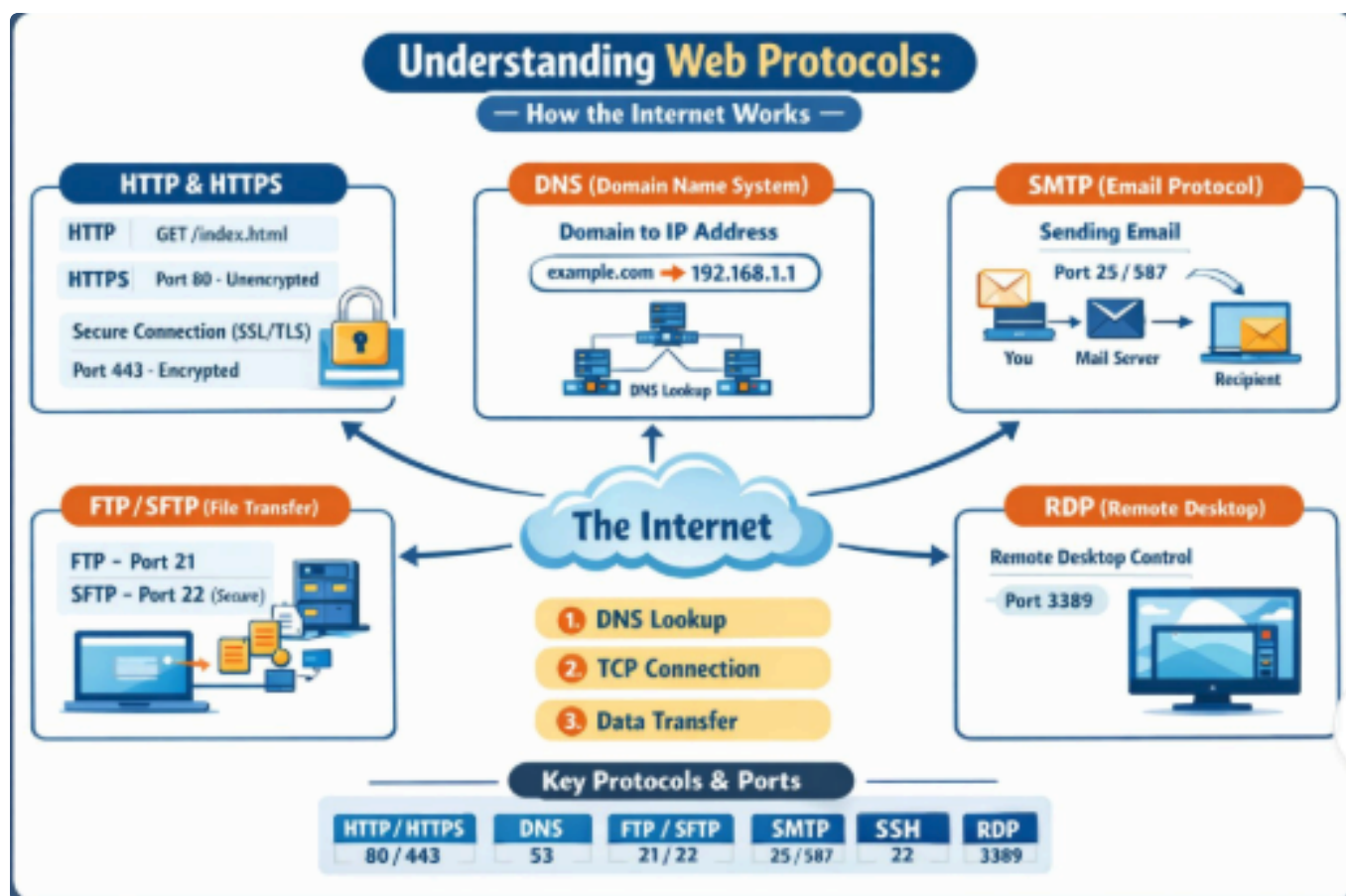
Class 14 DNS, Ports & Protocols FOR SOC 11

Protocols

What are Web Protocols?

A web protocol is simply a set of rules that define how data is sent and received over a network (especially the internet).

- Humans → language (English, Hindi)
- Computers → protocols (HTTP, HTTPS, DNS, etc.) Without protocols, devices wouldn't understand each other.



Where Do Web Protocols Fit?

Web protocols operate across layers of the OSI Model:

Layer	Example Protocols
Application	HTTP, HTTPS, DNS, FTP

Layer	Example Protocols
Transport	TCP,UDP
Network	IP
Data Link	Ethernet, WIFI

Common Protocols

HTTP - Hypertext Transfer Protocol

HTTP (HyperText Transfer Protocol) is the communication protocol used by web browsers and web servers to exchange data over the internet. When you visit a website, your browser sends an **HTTP request** to the web server. The server processes the request and sends back an **HTTP response** (such as a web page, image, or file).

Example:

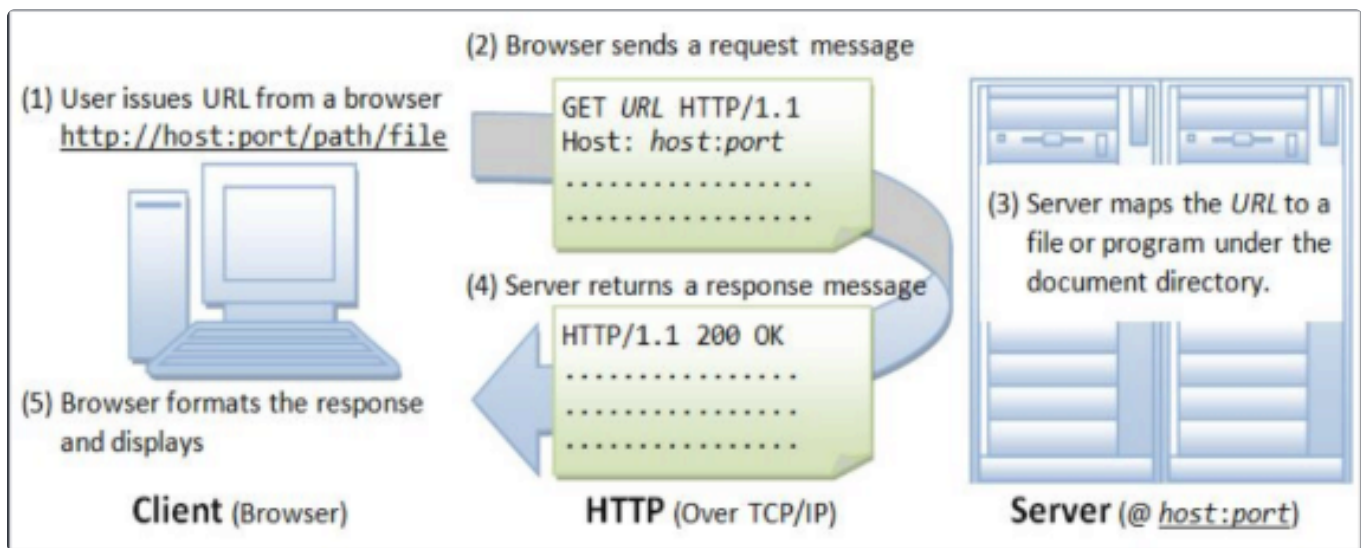
1. You enter `https://www.google.com`.
 2. Your browser sends an HTTP request to Google's server.
 3. Google's server sends an HTTP response containing the webpage.
 4. Your browser displays the page.
- Works on Port 80
 - Stateless (Important Concept) - **Stateless** means that **HTTP does not remember previous requests**. Every request is treated as a **new and independent request**, even if it comes from the same user.

Example 1 (Without Cookies or Sessions)

Suppose you visit an online shopping website.

- **Request 1:** Open the homepage.
- **Request 2:** Click on "Laptops."
- **Request 3:** Add a laptop to the cart.

From HTTP's perspective, each request is separate. The server does **not automatically know** that all three requests came from the same user.

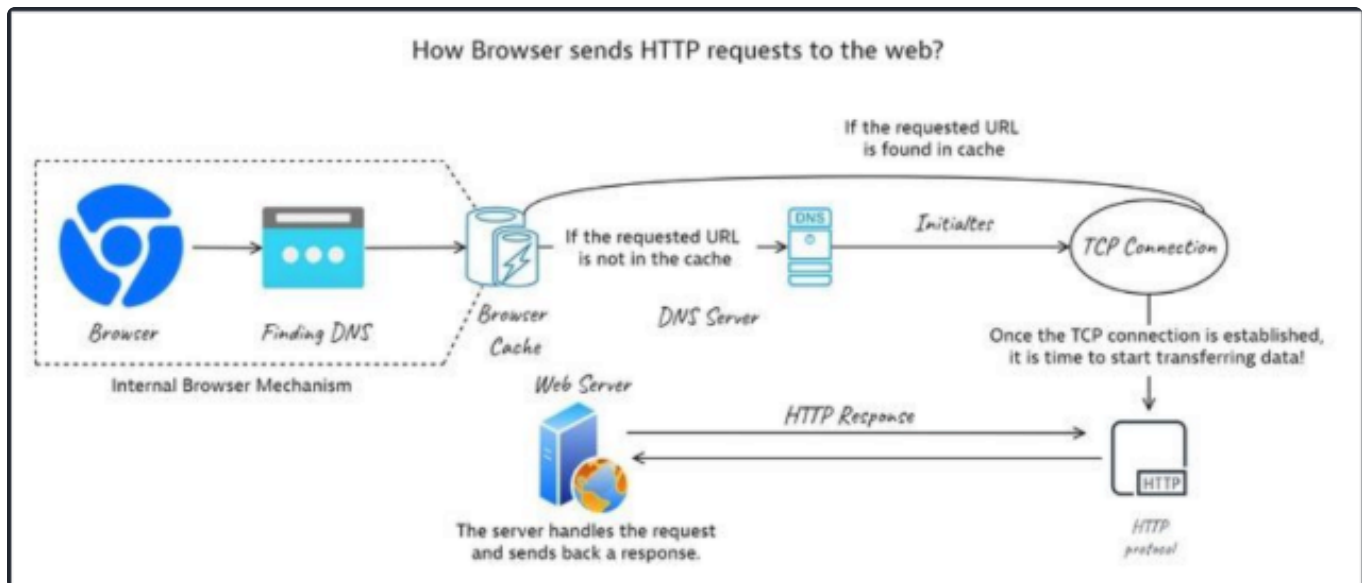


SOC Indicators (Why SOC Monitors Them)

- **Suspicious URLs:** May lead users to phishing websites or malware downloads.
- **Repeated Requests (/login brute force):** Indicates an attacker trying many username/password combinations to gain unauthorized access.
- **Unusual User-Agents:** Attackers often use automated tools or scripts that send fake or uncommon user-agent strings.
- **Large POST Requests:** May indicate data exfiltration (stealing data) or malicious file uploads to a server.

Common HTTP Attacks

- **XSS (Cross-Site Scripting):** An attacker injects malicious JavaScript into a website to steal user data, cookies, or sessions.
- **SQL Injection (SQLi):** An attacker inserts malicious SQL queries into user input to access, modify, or delete database data.
- **Credential Harvesting:** Attackers trick users into entering usernames and passwords on fake login pages (phishing).
- **HTTP Flood (DDoS):** Attackers send a massive number of HTTP requests to overwhelm a web server, making it slow or unavailable to legitimate users.



HTTP Methods

HTTP defines a set of request methods to indicate the purpose of the request and what is expected if the server does not automatically know that all three requests came from the same request is successful.

Stateless Nature (Very Important)

HTTP does NOT remember:

- Who you are
- Previous requests

That's why we use:

- Cookies
- Sessions
- Tokens

Method	Purpose
GET	Fetch Data
POST	Send Data
PUT	Update resources
DELETE	Remove Resources
PATCH	Partial Update

HTTP Status Code

HTTP response status codes indicate whether a specific HTTP request has

been successfully completed. Responses are grouped in five classes:

1. Information Responses (100-199)
2. Successful responses (200-299)
3. Redirection message (300-399)
4. Client error responses (400-499)
5. Server error responses (500-599)

CODE	MEANING
200	OK
301	Redirect
400	Bad Request
401	Unauthorized
403	Forbidden
404	Not Found
500	Server Error

HTTPS (Secure HTTP)

What is HTTPS?

HTTPS (HyperText Transfer Protocol Secure) is the secure version of HTTP. It uses **SSL/TLS encryption** to protect data exchanged between the client (browser) and the server.

- **Port:** 443
- **Uses:** SSL/TLS encryption

HTTPS Provides

- **Confidentiality:** Encrypts data so only the sender and receiver can read it.
- **Integrity:** Ensures data is not modified or tampered with during transmission.
- **Authentication:** Verifies that the client is communicating with the legitimate website using a digital certificate.

Why HTTPS Matters

Without HTTPS:

- **MITM (Man-in-the-Middle) Attacks:** An attacker can intercept and read or modify the communication between the client and server.
- **Credentials Can Be Sniffed:** Usernames and passwords sent over HTTP can be captured by attackers.
- **Data is Readable in Plaintext:** Sensitive information such as login credentials, banking details, or personal data is transmitted without encryption, making it easy to steal.

DNS (Domain Name System)

What is DNS?

DNS (Domain Name System) is known as the **phonebook of the Internet**. It translates **human-readable domain names** into **IP addresses** so computers can find and communicate with websites.

Example:

- google.com → 142.250.x.x

Without DNS, users would have to remember IP addresses instead of website names.

DNS Uses

- **Port:** 53
- **Protocol:** Mostly **UDP** (because it is faster). **TCP** is used for large responses or zone transfers.

DNS Resolution Process

1. Browser Cache

- The browser first checks if it already knows the IP address from a previous visit.

2. OS Cache

- If not found, the operating system checks its local DNS cache.

3. DNS Resolver (ISP/Public DNS)

- If the IP is still unknown, the request is sent to a DNS resolver (usually provided by your ISP or services like Google DNS or Cloudflare DNS).

4. Root Server

- The resolver contacts a **Root DNS Server**, which directs it to the correct **Top-Level Domain (TLD)** server.

5. TLD Server

- The **TLD Server** (e.g., `.com`, `.org`, `.net`) points the resolver to the website's **Authoritative DNS Server**.

6. Authoritative Server

- The **Authoritative DNS Server** returns the correct IP address for the requested domain.
- The browser then uses this IP address to connect to the website.

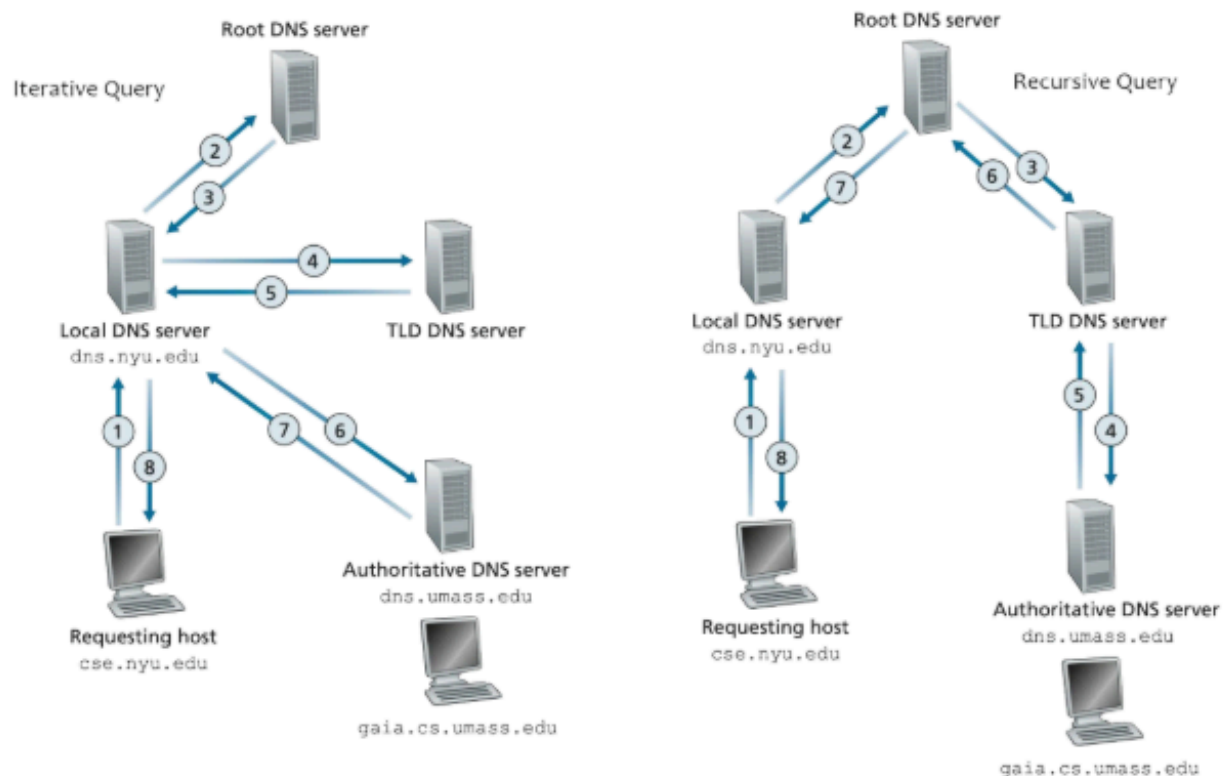
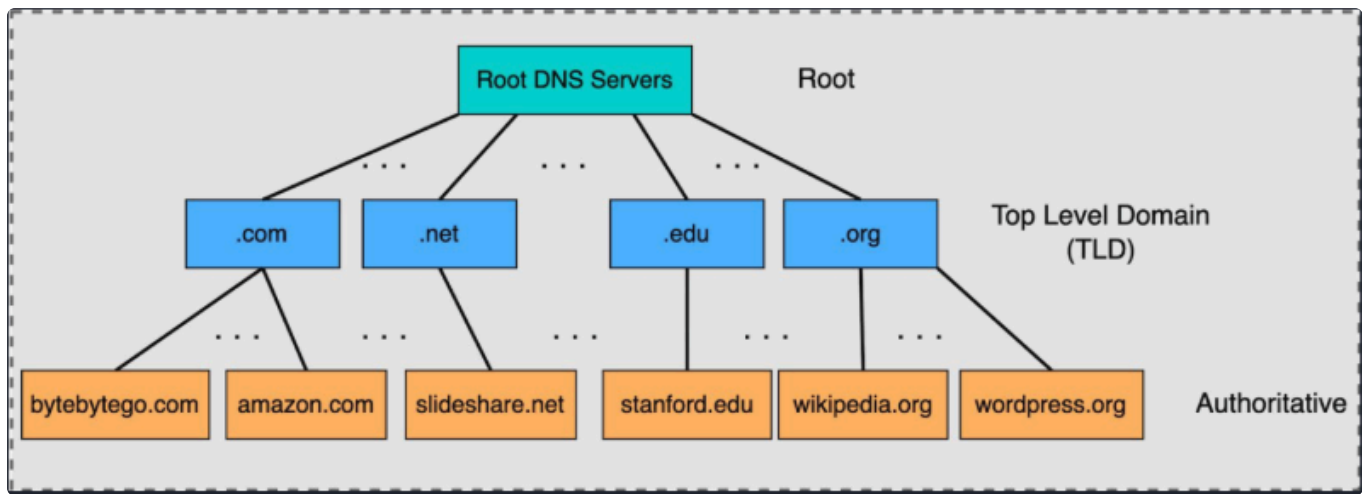
Simple Flow

```
graph TD; A[User enters google.com] --> B[Browser Cache]; B --> C[OS Cache]; C --> D["DNS Resolver (ISP/Public DNS)"]; D --> E[Root Server]; E --> F["TLD Server (.com)"]; F --> G[Authoritative DNS Server]; G --> H[ ];
```

Returns IP Address



Browser connects to the website



SOC Indicators (Why SOC Monitors Them)

1. Too Many DNS Requests

- If a device sends an unusually high number of DNS queries, it may be infected with malware trying to contact many domains or communicate with an attacker.

2. Suspicious Domains

- Domains that are newly registered, misspelled (e.g., `g00gle.com`), or have a bad reputation may be phishing or malware websites.

3. Random Subdomains

- Malware often generates random subdomains like:

```
x8k2ab.example.com  
jh93sd.example.com
```

This may indicate **DNS tunneling** or **DGA-based malware**.

4. DNS Tunneling

- Attackers misuse DNS queries to secretly send or receive data, bypassing firewall restrictions because DNS traffic is usually allowed.

Common DNS Attacks

1. DNS Spoofing

- The attacker provides a **fake DNS response**, redirecting users to a malicious website instead of the legitimate one.

Example:

```
bank.com  
  ↓  
Fake DNS Response  
  ↓  
attacker-website.com
```

2. DNS Tunneling (Data Exfiltration)

- Attackers hide stolen data inside DNS requests and send it to a domain they control.
 - Used to **steal sensitive information** or maintain communication with infected systems.
-

3. DGA (Domain Generation Algorithm)

- Malware automatically generates **thousands of random domain names** every day.
- The attacker only needs to register one of these domains for the malware to reconnect.

Example:

```
ajd82ks.com  
xk93pq.net  
mzn72ab.org
```

This makes it difficult for defenders to block all possible domains.

FTP/SFTP

FTP (File Transfer Protocol) is a protocol used to **transfer files** between computers over a network.

- **Port:** 21
- **Security:** ❌ Not secure (data, usernames, and passwords are sent in plaintext).

FTP Modes

- **Active Mode:** The server initiates the data connection to the client.
- **Passive Mode:** The client initiates both the control and data connections. This is more firewall-friendly and commonly used.

What is SFTP?

SFTP (Secure File Transfer Protocol) is a secure way to transfer files.

- **Runs over:** SSH
- **Port:** 22
- **Security:** ✅ Encrypts all data, usernames, passwords, and file transfers.

SOC Indicators (Why SOC Monitors Them)

1. Large File Transfers

- A large amount of data being transferred may indicate **data theft (data exfiltration)** or unauthorized backups.

2. Unknown Uploads

- Uploading files to unknown or unauthorized servers may indicate malware activity or an attacker stealing data.

3. Anonymous Login

- FTP allows anonymous access if enabled. Attackers can misuse this to access or upload files without authentication.

Common FTP/SFTP Attacks

1. Credential Sniffing (FTP)

- Since FTP sends credentials in plaintext, attackers can capture usernames and passwords by monitoring network traffic.

2. Data Exfiltration

- Attackers use FTP or SFTP to transfer stolen files from the victim's system to their own server.

3. Brute Force Login

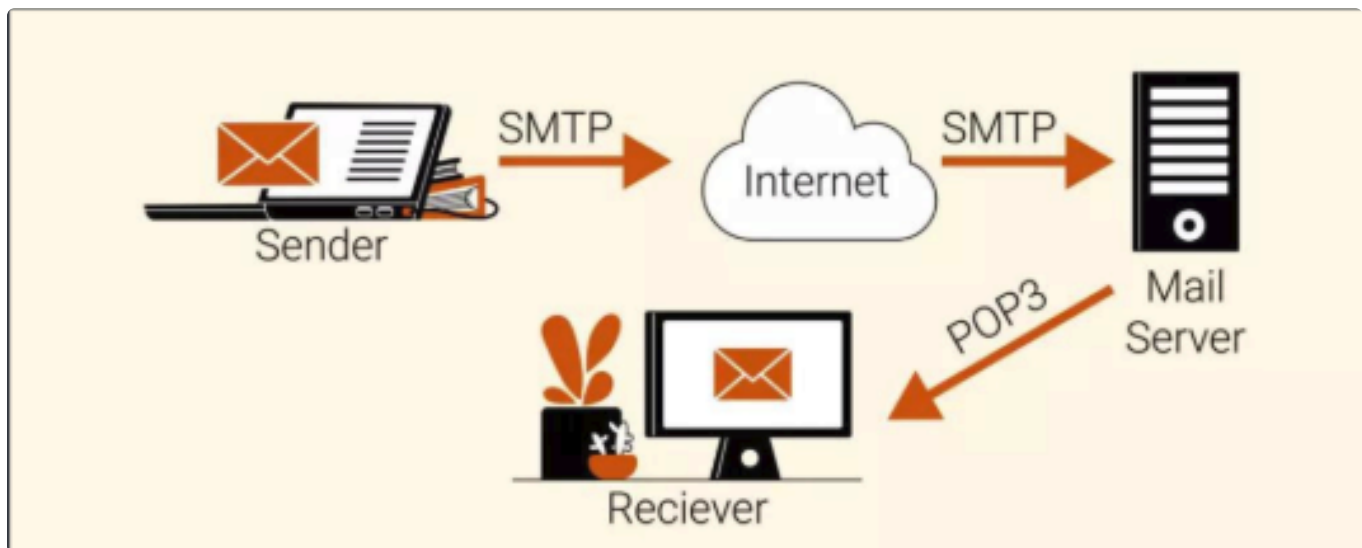
- Attackers repeatedly try different username and password combinations until they successfully log in.

SMTP (Simple Mail Transfer Protocol)

What is SMTP?

SMTP (Simple Mail Transfer Protocol) is the protocol used to **send emails** from a sender to a mail server or between mail servers.

- **Purpose:** Sends emails
 - **Port 25:** SMTP (server-to-server communication)
 - **Port 587:** Secure email submission from email clients (uses encryption with STARTTLS)
-



SOC Indicators (Why SOC Monitors Them)

1. Bulk Email Sending

- A user or system sending a large number of emails in a short time may indicate a **spam campaign** or a compromised email account.

2. Unknown Sender Domains

- Emails coming from unfamiliar or suspicious domains may be phishing attempts or malicious emails.

3. Email Spoofing

- Attackers forge the sender's email address to make the email appear as if it came from a trusted person or organization.
-

Common SMTP Attacks

1. Phishing

- Attackers send fake emails pretending to be trusted organizations to trick users into revealing passwords, clicking malicious links, or downloading malware.

2. Spam Campaigns

- Attackers send large volumes of unwanted emails, often containing advertisements, phishing links, or malware.

SSH (Secure Shell)

What is SSH?

SSH (Secure Shell) is a secure protocol used to **remotely access and manage another computer** over a network.

- **Purpose:** Secure remote login and command execution.
 - **Port:** 22
 - **Security:** Encrypts all communication, including usernames, passwords, and commands.
-

SOC Indicators (Why SOC Monitors Them)

1. Multiple Failed Logins

- Many failed SSH login attempts may indicate a **brute force attack**, where an attacker is trying different passwords.

2. Login from Unusual IP

- An SSH login from an unfamiliar or unexpected IP address may indicate **unauthorized access** or a compromised account.

3. Root Login Attempts

- Attackers often target the **root** account because it has full administrative privileges. Multiple root login attempts are highly suspicious.
-

Common SSH Attacks

1. Brute Force

- Attackers repeatedly try different username and password combinations until they successfully log in.

2. Credential Theft

- Attackers use stolen usernames, passwords, or SSH private keys to log in as legitimate users.

3. Unauthorized Access

- An attacker gains SSH access to a system without permission, allowing them to execute commands, steal data, or install malware.

RDP (Remote Desktop Protocol)

RDP (Remote Desktop Protocol) is a Microsoft protocol that allows a user to **remotely access and control a Windows computer** as if they were sitting in front of it.

- **Purpose:** Remote access and management of Windows systems.
 - **Port:** 3389
-

SOC Indicators (Why SOC Monitors Them)

1. Login at Odd Hours

- A login late at night or outside normal working hours may indicate unauthorized access by an attacker.

2. Multiple Login Attempts

- Many failed login attempts may indicate a **brute force attack**, where an attacker is trying different passwords.

3. External IP Login

- An RDP login from an unknown or external IP address may indicate an attacker accessing the system remotely.

Common RDP Attacks

1. RDP Brute Force

- Attackers repeatedly try different username and password combinations until they successfully log in.

2. Lateral Movement

- After compromising one system, attackers use RDP to move to other computers within the network to expand their access.

3. Ransomware Entry Point

- Attackers often gain access through exposed RDP, then deploy ransomware to encrypt files across the victim's systems.

SMB (Server Message Block)

What is SMB?

SMB (Server Message Block) is a Windows network protocol used to **share files, folders, printers, and other resources** between computers on the same network.

- **Purpose:** File and resource sharing in Windows networks.
- **Port:** 445

SOC Indicators (Why SOC Monitors Them)

1. Access to Admin Shares (C\$)

- **C\$** is a hidden administrative share on Windows.
- Unauthorized access to **C\$** may indicate an attacker trying to gain administrative control or move files.

2. File Movement Across Systems

- Large or unusual file transfers between computers may indicate malware spreading or attackers copying stolen data.

3. Lateral Movement

- If a compromised system starts connecting to multiple other systems using SMB, it may indicate an attacker spreading through the network.
-

Common SMB Attacks

1. EternalBlue Exploit

- Attackers exploit a vulnerability in SMB (MS17-010) to gain unauthorized access and execute malicious code.
- This exploit was famously used by the **WannaCry ransomware**.

2. SMB Relay

- Attackers intercept and relay SMB authentication requests to another server, allowing them to authenticate without knowing the user's password.

3. Lateral Movement

- After compromising one computer, attackers use SMB to access shared folders and spread to other systems in the network.

What is Computer Port?

A **computer port** is a **virtual communication endpoint** that allows different applications and services to send and receive data over a network.

Think of a port as a **door** to a specific service running on a computer. Although all network traffic arrives at the same IP address, the **port number** tells the operating system **which application should receive the data**.

Example:

- **Port 80** → HTTP (Web browsing)
- **Port 443** → HTTPS (Secure web browsing)
- **Port 22** → SSH (Secure remote login)

- **Port 25** → SMTP (Email sending)
-

Why are Ports Needed?

A single computer can run multiple network services at the same time. Ports help the operating system distinguish between them.

For example:

- A web browser uses **Port 443** to access secure websites.
- An email application uses **Port 25** or **587** to send emails.
- An SSH client uses **Port 22** to connect to a remote server.

Without ports, the operating system wouldn't know which application should handle incoming network traffic.

Port Numbers

- There are **65,535** possible port numbers (0-65535).
- Each port is assigned to a specific service or application.

Port Ranges

- **0-1023**: Well-known ports (HTTP, HTTPS, SSH, FTP, SMTP, etc.)
- **1024-49151**: Registered ports (used by applications and services)
- **49152-65535**: Dynamic/Ephemeral ports (temporary ports used by clients)

Types of Computer Ports

Ports are numbered from **0** to **65535** and are divided into different categories based on their purpose.

1. Well-Known Ports (0-1023)

- These ports are **reserved for common and standard network services**.
- They are used by widely known protocols.

Examples:

- **HTTP** – Port **80**
 - **HTTPS** – Port **443**
 - **FTP** – Port **21**
 - **SSH** – Port **22**
-

2. Registered Ports (1024–49151)

- These ports are **assigned to specific applications and services**.
- They are commonly used by software such as databases and enterprise applications.

Examples:

- **MySQL** – Port **3306**
 - **Microsoft SQL Server** – Port **1433**
 - **RDP** – Port **3389**
-

3. Dynamic/Private Ports (49152–65535)

- These ports are **temporarily assigned by the operating system** for client connections.
- They are also called **ephemeral ports** because they are used only for the duration of a connection.

Example:

- When your browser connects to `https://google.com` (Port **443**), your computer automatically uses a temporary port such as **52341** to establish the connection.
-

4. Internal Ports

- Used **inside a private network (LAN)** for communication between devices.
- They are **not directly accessible from the internet**.

- Example: A PC communicating with a local file server inside an office network.

5. External Ports

- These ports are **accessible from the internet**.
- Routers use **Port Forwarding** to map an external port to an internal device or service.
- This allows external users to access services such as a web server or game server hosted inside a private network.

Example:

- An internet user accesses your website using **Port 443**, and the router forwards that traffic to your internal web server.

Important Ports

Port	Protocol	Use
21	FTP	File transfer
22	SSH	Secure remote access
25	SMTP	Email sending
53	DNS	Domain resolution
80	HTTP	Web traffic
443	HTTPS	Secure web
3389	RDP	Remote desktop
445	SMB	File sharing

Real SOC Example

Source IP: 185.221.x.x

Destination IP: 192.168.1.10

Port: 3389

Attempts:500

Status: Failed

Immediately think: RDP Brute Force Attack